

ESCUELA
COLOMBIANA
DE INGENIERÍA
JULIO GARAVITO

ISMS

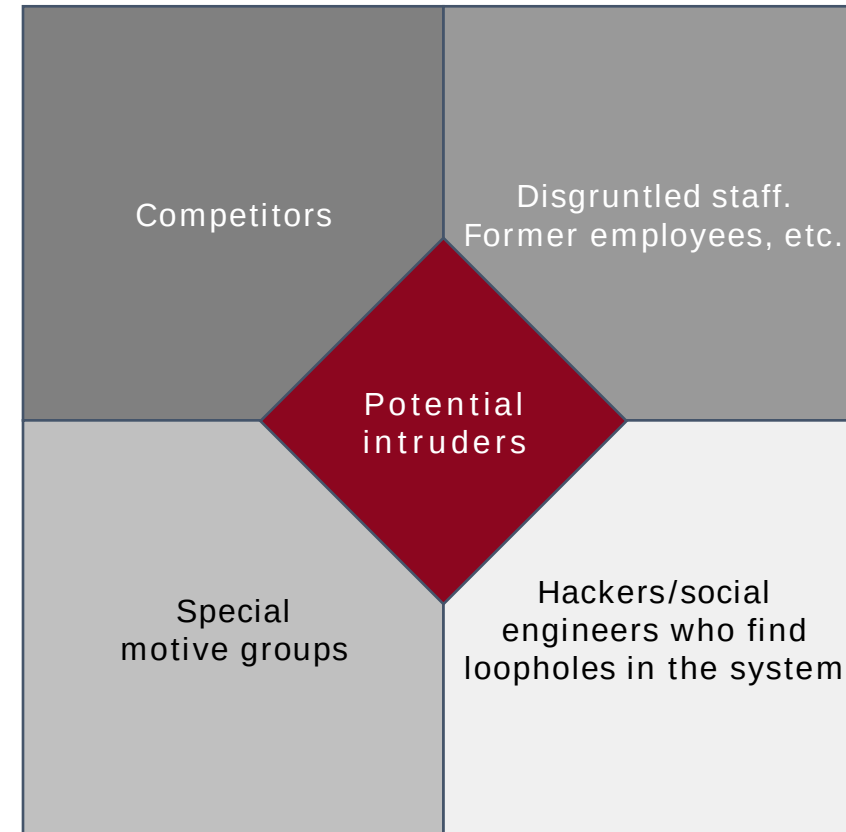
Information Security Management System

SPTI

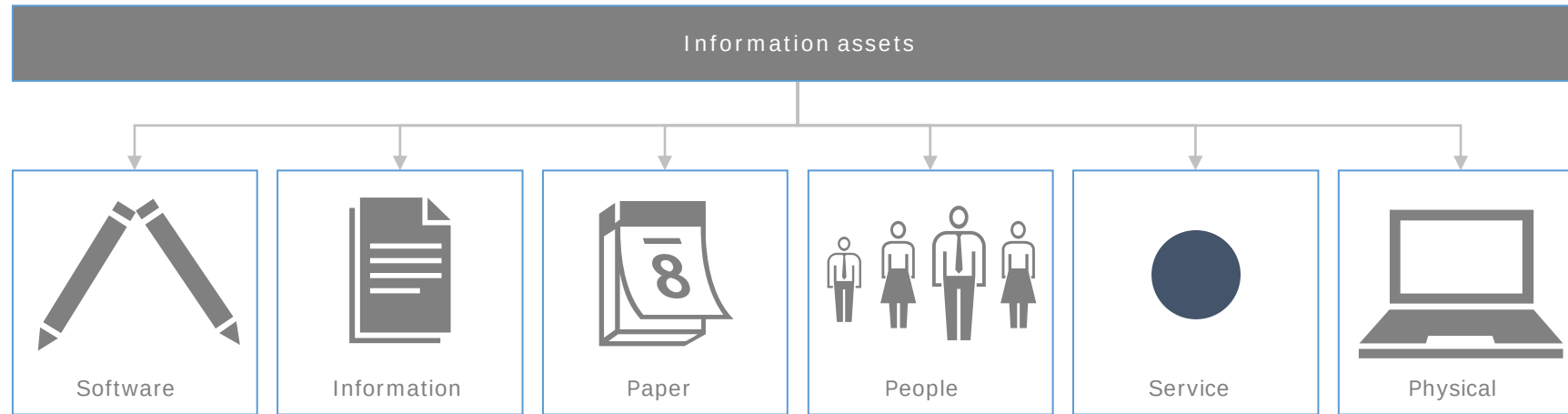
Impact of security breaches on our business

Consequences of security breaches

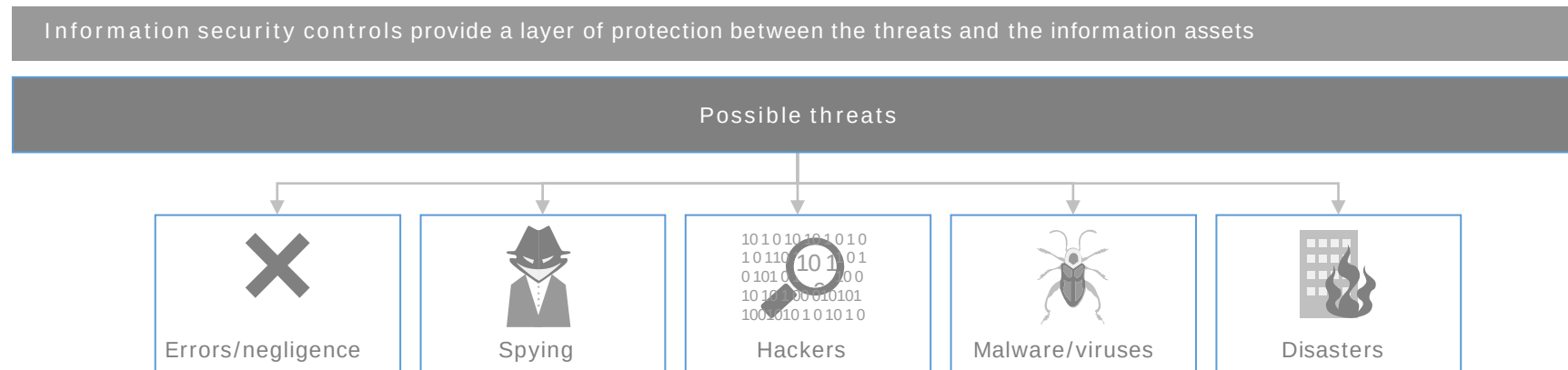
- ▶ Damage to reputation
- ▶ Loss of market and customer confidence
- ▶ Disruption in business
- ▶ Direct and indirect financial loss
- ▶ Competitive edge in the industry jeopardized
- ▶ Closure of business



Threats and vulnerabilities to information



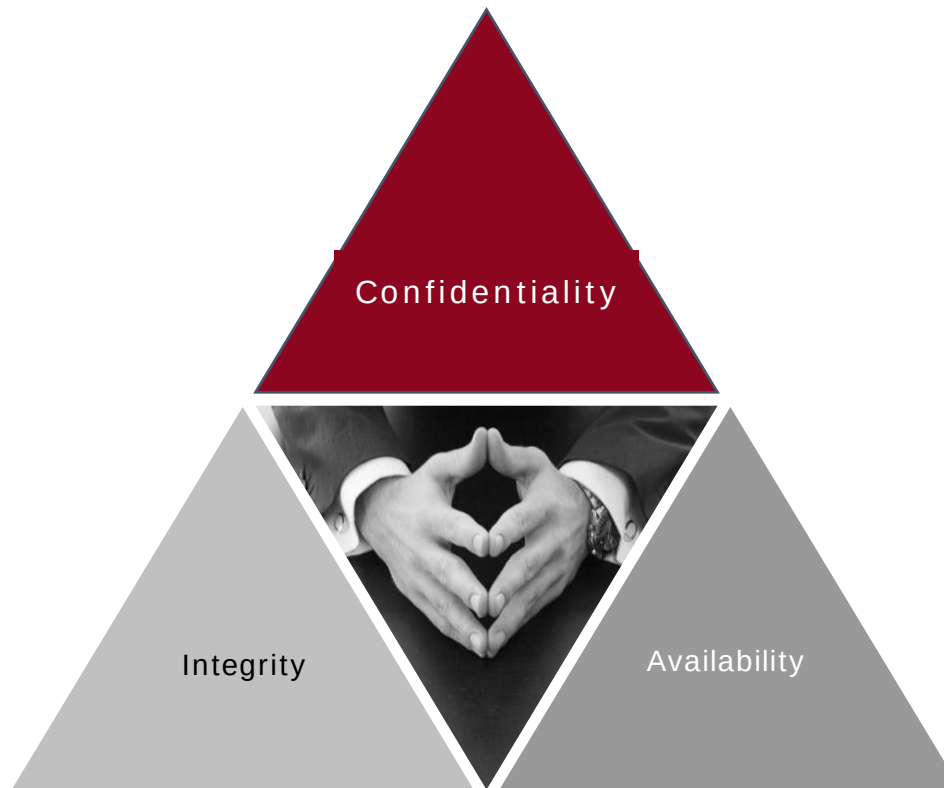
Vulnerabilities are weaknesses associated with information assets, which could be exploited by threats.



Threats are anything that could cause damage/harm/loss to assets.

Information security model

Security is built on three pillars of **people, processes and technology**. Weakness in any one of them could compromise the Company's security.



Information security helps in protecting

Confidentiality

- ▶ Confirming that information is accessed by only those who have authorization to have access to it

Integrity

- ▶ Safeguarding the accuracy and completeness of information and its processing methods

Availability

- ▶ Confirming that authorized users have access to information whenever required by them

Reasons to Implement a Management System

A management information system **helps a company become more competitive**. It reports and identifies what is working and what is not. These reports give owners the information they need to make decisions and improve the performance of their employees and the business.

- Establishes a common documented framework to achieve more consistent implementation of compliance policies and processes
- Provides clear methods and processes to identify and prioritize risks, set and monitor goals, communicate those risks to employees and management, and allocate the resources to mitigate them.
- Empowers facilities to take responsibility for processes and compliance performance without waiting to be told “what” and “how”.
- Enables better collaboration and communication across a distributed company with many locations.
- Enables the selection and implementation of a robust information system capable of tracking and reporting on common activities and performance metrics across the company.
- Creates consistent processes and procedures that support personnel changes (e.g., transfers, promotions, retirements) and training of new personnel without causing disruption or gaps.
- Allows for more consistent oversight and governance, yielding higher predictability and reliability.

Key Benefits of an ISMS

The benefit of a framework such as ISO 27001 is that it is a simple and straightforward approach to a highly complex undertaking.

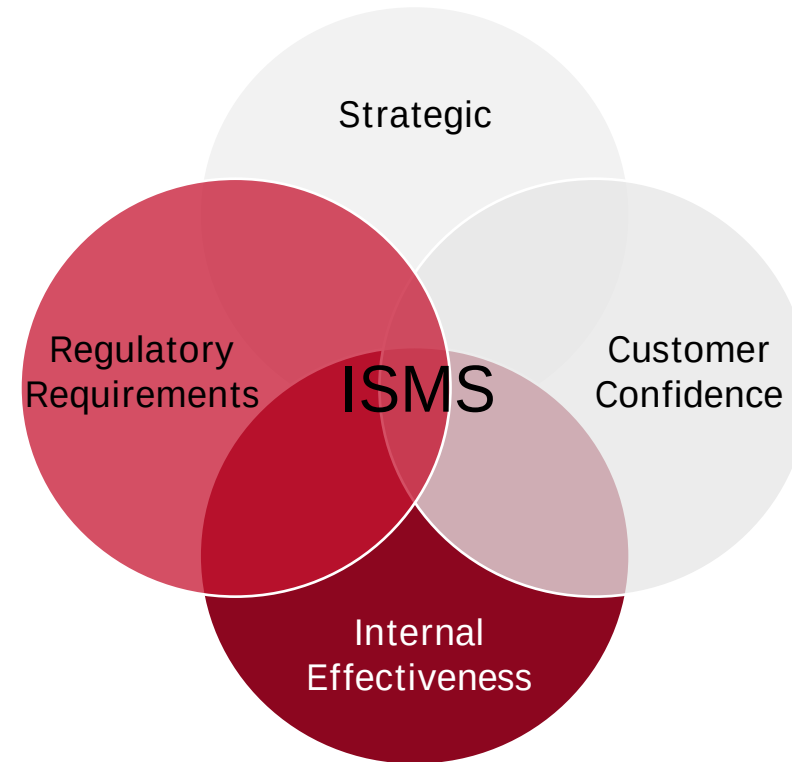
Reasons for implementing an the ISO 27002 controls and the ISO 27001 ISMS include but not limited to:

Strategic – better manage security within the broader external risk environment

Customer Confidence – show customers that their data will be reasonably protected by the organization, or to differentiate the organization from competitors

Regulatory Requirements – introduce a framework to integrate and manage widely varying regulations

Internal Effectiveness – managing information effectively as a good practice



ISO 27001 – Management Standard

ISO 27001 is referred to as a “specification” for the design and operation of an Information Security Management System

ISO 27001 is what is being referred to when “ISO certification” is discussed

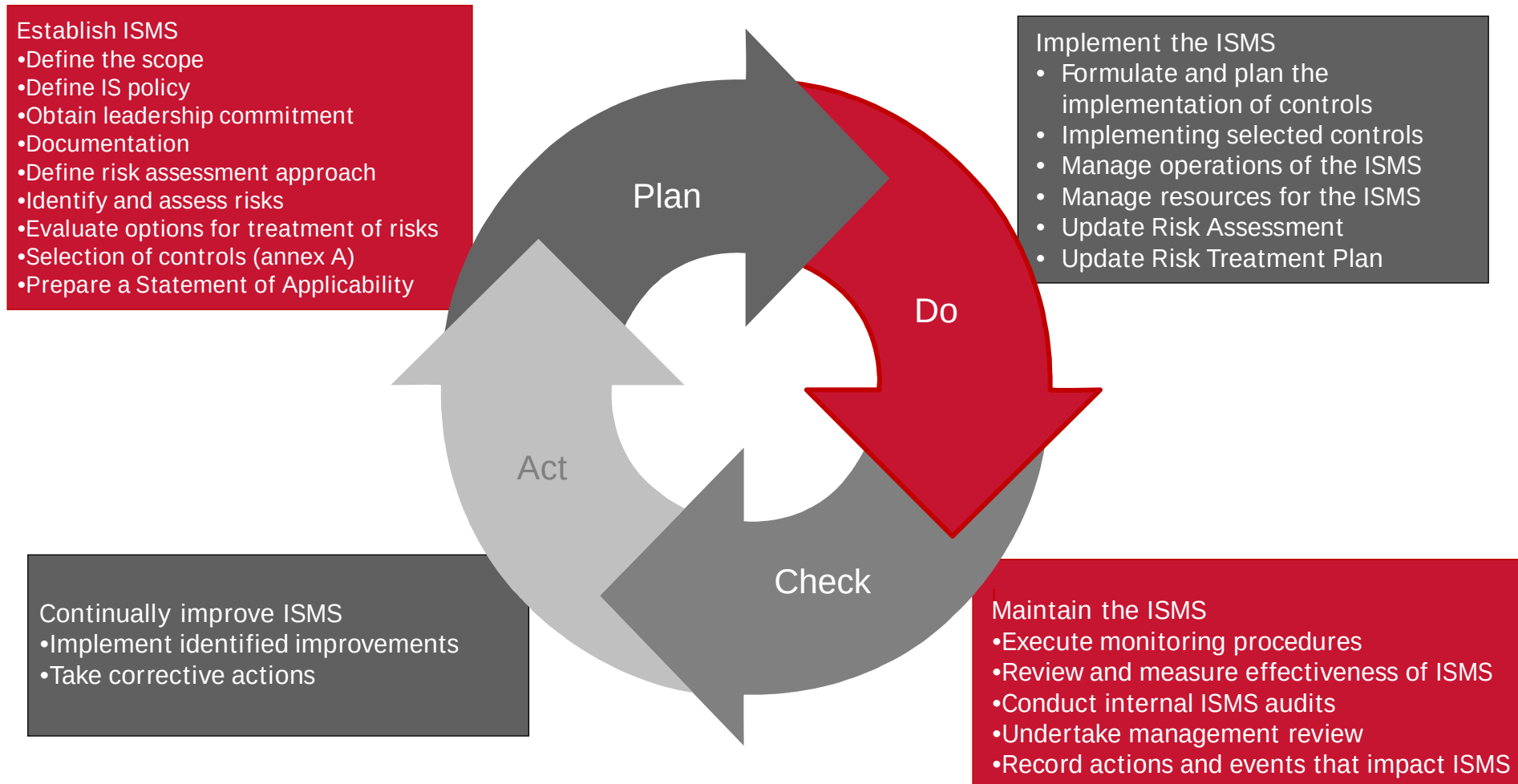
Specification uses phrasing such as “must” and “shall”, indicating that elements presented within the specification are not optional

ISO 27001 requires implementation of a number of elements, such as:

Understanding Context	Leadership Commitment
Asset Identification	Risk Assessment
Risk Treatment	Incident Monitoring
Performance Evaluation	Improvement

ISO 27001 methodology

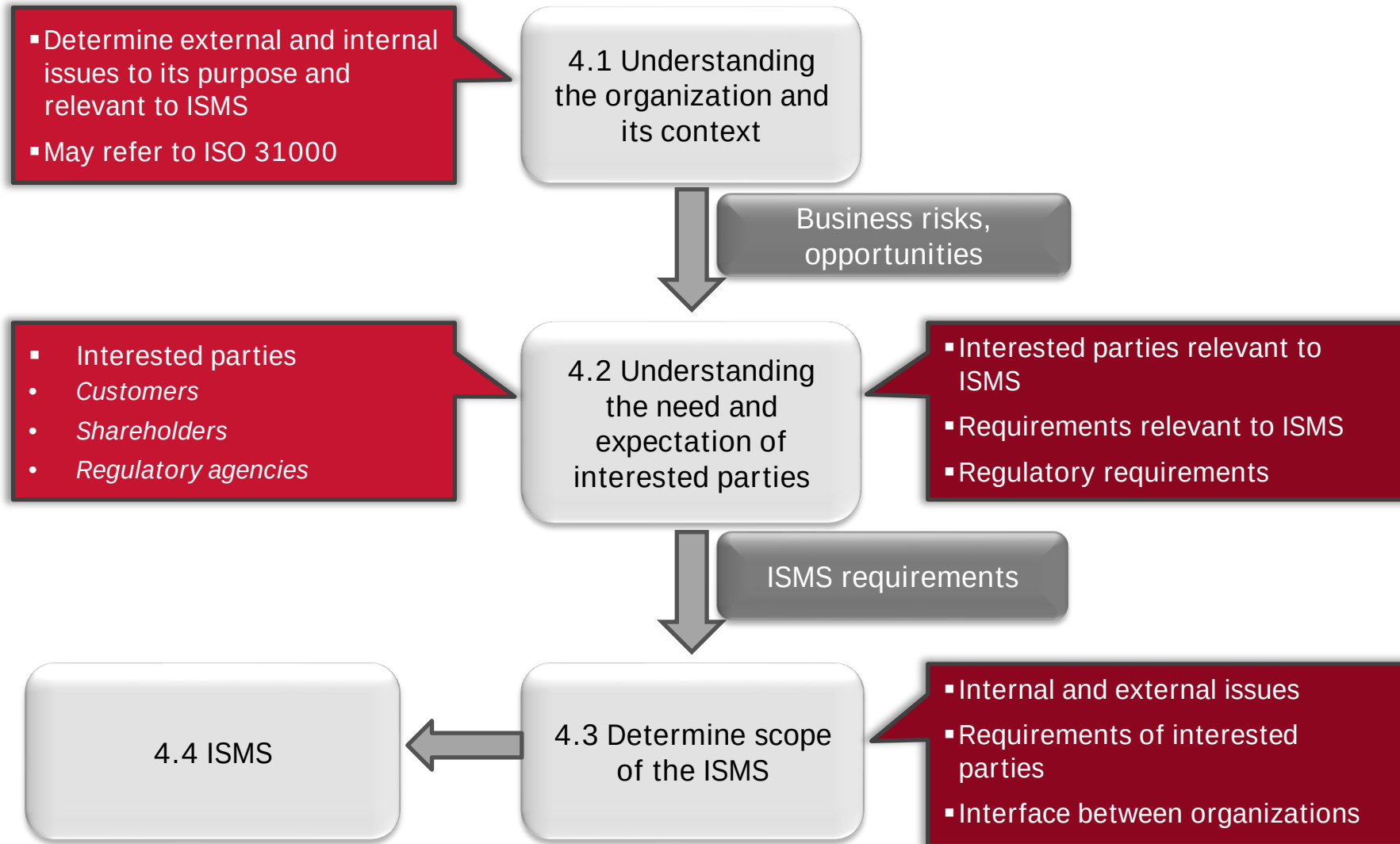
The ISO 27001 methodology is highly mature has been successfully across the world. The implementation of an ISMS can be further detailed by representing the various stages of the Plan Do Check Act model with the detailed activities described in ISO 27001:2013



Overview of the Standard (ISO 27001:2013)



Context of the organization



Context of the organization – Regulatory framework

CONPES 3701 DE 2011

Lineamientos
CiberSeguridad y
Ciberdefensa

Ley 527 de 1999

Validez jurídica y
probatoria de la
información electrónica

Ley 594 de 2000

Ley General de Archivos –
Criterios de Seguridad

Ley 679 de 2001

Pornografía Infantil –
Responsabilidad ISPs

Ley 962 de 2005

Simplificación y Racionalización
de Trámite. Atributos de
seguridad en la
información electrónica de
entidades públicas

Ley 1150 de 2007

Seguridad de la
información electrónica en
contratación en línea

Ley 1266 de 2008

Habeas data financiera, y
seguridad en datos
personales

Ley 1273 de 2008

Delitos Informáticos y
protección del bien jurídico
tutelado que es la
información

Ley 1341 de 2009

Tecnologías de la
Información y aplicación
de seguridad

Ley 1437 de 2011

Procedimiento
Administrativo y aplicación
de criterios de seguridad

Ley 1480 de 2011

Protección al consumidor
por medios electrónicos.
Seguridad en
transacciones electrónicas

Decreto Ley 019 de 2012

Racionalización de trámites
a través de medios
electrónicos. Criterio de
seguridad

Ley 1581 de 2012

Ley estatutaria de
Protección de datos
personales

Ley 1623 de 2013

Ley de Inteligencia –
Criterios de seguridad

Ley 1712 de 2014

Transparencia en el acceso
a la información pública

Context of the organization – Legal framework

Decreto 2364 de 2012

Firma
electrónica

Decreto 2609 de
2012

Expediente
electrónico

Decreto 2693 de
2012

Gobierno
electrónico

Decreto 1377 de
2013

Protección de
datos
personales

Decreto 1510 de
2013

Contratación
Pública
electrónica

Decreto 333 de
2014

Entidades de
certificación
digital

Scope definition

When creating a certification scope, a number of considerations should be addressed. These considerations help identify a logical and optimum scope for certification.

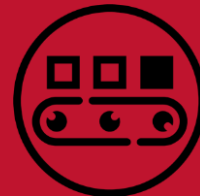
- What legal or management entity will be responsible and accountable for the ISMS?



- What information assets are owned, operated or depended upon by the entity?



- What processes are involved in manipulating, storing or sharing that information?



- What legal and regulatory requirements apply to that information?



Leadership

5.1 Leadership and commitment

- Top management have to provide evidence of:
 - *Directing and supporting personnel*
 - *Supporting next level management to demonstrate leadership*

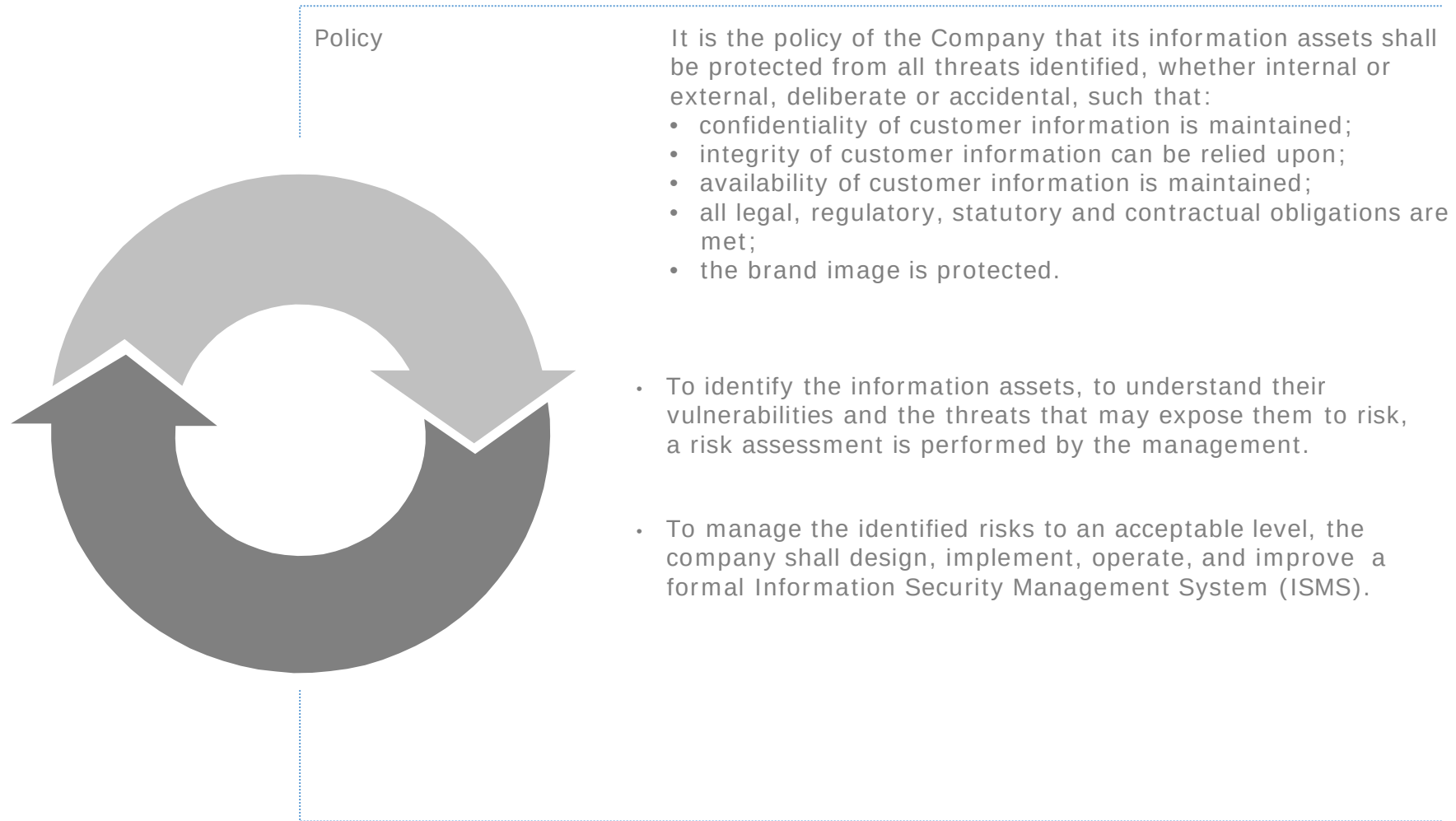
5.2 Policy

- Policy should include a statement of continual improvement.
- Policy should be communicated

5.3 Organizational roles, responsibilities and authorities

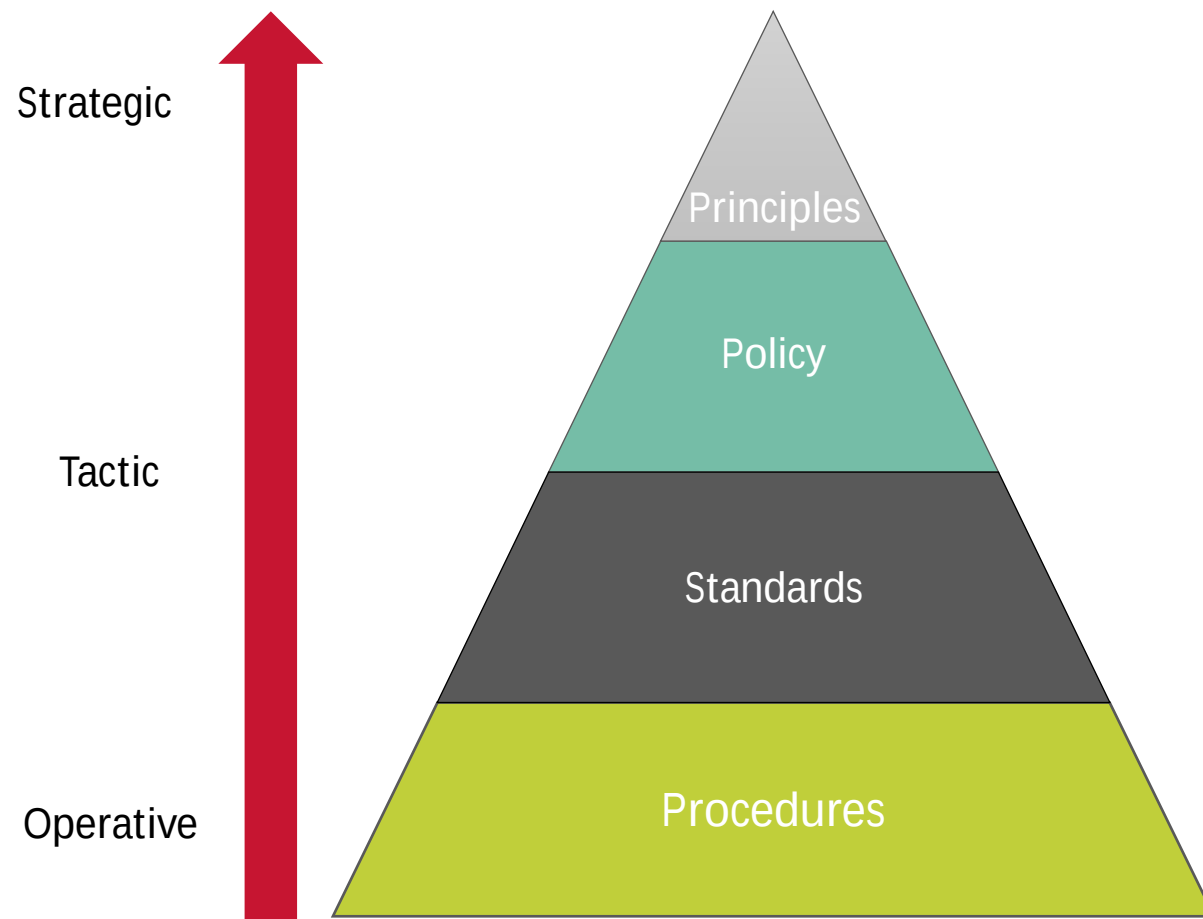
- More explicit requirements for defining line of reporting and authorities..

Leadership - Information Security Policy



Leadership - Information Security Policy

- ✓ Help bring a company into compliance with legal, regulatory, and statutory requirements
- ✓ Minimize internal and external risks to customer information and our business
- ✓ Limit the risk of security and privacy breaches
- ✓ Provide continuous protection that allows for a flexible, effective, and defensible approach to security and privacy
- ✓ Reduce operational risk where threats are assessed and vulnerabilities are mitigated
- ✓ Increase overall organizational efficiency and operational performance
- ✓ Enhance our reputation and potentially gain a competitive advantage



6.1 Actions to address risks and opportunities

- ISMS planning to address business risks and opportunities
- Establish method for information security risk assessment
- Identify risk owners
- Risk owners approval of residual risks

6.2 ISMS objectives and planning to achieve them

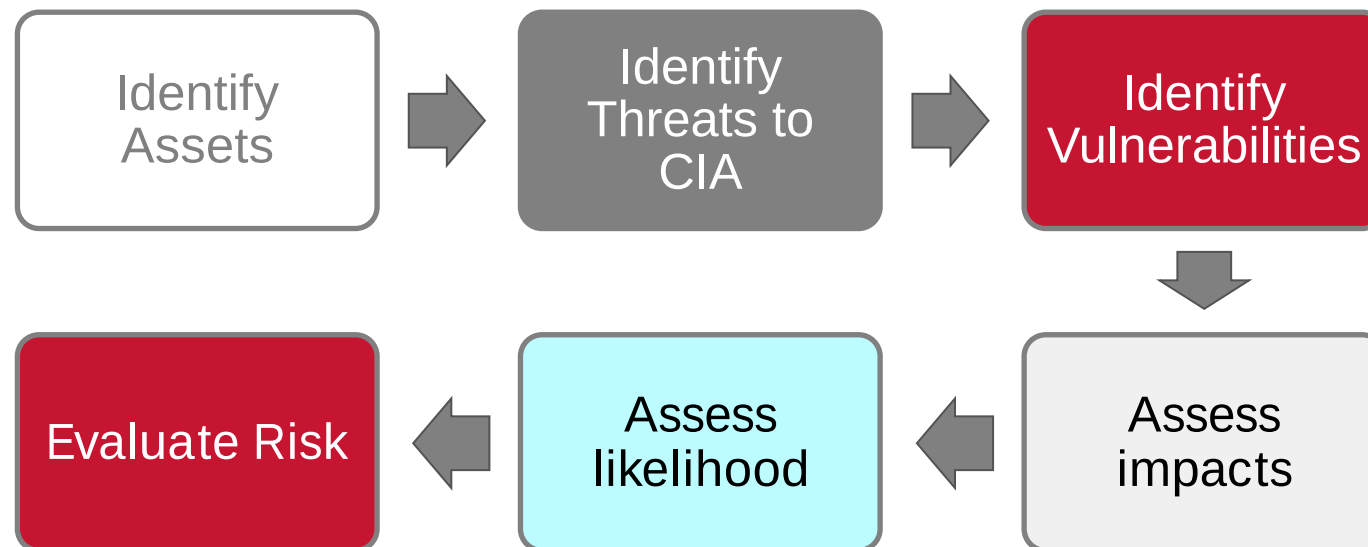
- ISMS objectives for different functions and levels
- Objectives should be measurable
- Consistent with risk treatment plan
- Develop plan to achieve objectives

Planning – Risk Assessment methodology

Risk assessment is the process of identifying threats with the potential to exploit vulnerabilities in identified assets and rating them based on their likelihood of occurrence and potential impact.

- ▶ Identification of in-scope assets is the first step in the risk assessment process.
- ▶ All assets must have a documented owner.

The standard sets out 6 steps that must be followed when developing a risk assessment methodology:



7.1 Resource

- The organization shall determine and provide the resources needed for the establishment, implementation, maintenance and continual improvement of the information security management system.

7.2 Competency

- Determine the necessary competence of person(s) doing work under its control that affects its information security performance;
- Ensure that these persons are competent on the basis of appropriate education, training, or experience;
- Where applicable, take actions to acquire the necessary competence, and evaluate the effectiveness of the actions taken; and
- Retain appropriate documented information as evidence of competence.

7.3 Awareness

- Persons doing work under the organization's control shall be aware of:
 - *The information security policy;*
 - *Their contribution to the effectiveness of the information security management system, including the benefits of improved information security performance; and*
 - *The implications of not conforming with the information security management system requirements.*

7.4 Communication

- Need to define a procedure for internal and external communication

7.5 Documented information

- Need to define process for document creation, approval and release

8.1 Operational planning and control

- Implement the plan identified in 6.2
- Determine operational controls required to operate ISMS
- Identify controls required for outsourced process

8.2 Information security risk assessment

- The organization shall perform information security risk assessments at planned intervals or when significant changes are proposed or occur, taking account of the criteria established in 6.1.2).
- The organization shall retain documented information of the results of the information security risk assessments.

8.3 Information security risk treatment

- The organization shall implement the information security risk treatment plan.
- The organization shall retain documented information of the results of the information security risk treatment.

9.1 Monitoring, measurement, analysis and evaluation

- Organization shall determine:
 - *What needs to be monitored and measured*
 - *Method of monitoring, measurement, analysis and evaluation*
 - *When monitoring and measuring to be performed and who will perform.*
 - *When results of monitoring to be analyzed and evaluated. Who will perform.*

9.2 Internal audit

- Risk-based assessments of ISMS
- Ensure that required controls (from SoA) are effective and being applied
- Applies to functional and technical requirements
- Frequency of audits should be commensurate with risk level and degree of dependency of controls

9.3 Management review

- Mandate to take corrective and preventative action via operation of controls
- Management is directed to collect improvement recommendations and mandate that they be incorporated into the existing ISMS
- Additionally a mandate to “apply lessons learned from the security experiences of other organizations and those of the organization itself”

Perform evaluation - Monitor and Review the ISMS

Audits

- Risk-based assessments of ISMS
- Ensure that required controls (from SoA) are effective and being applied
- Applies to functional and technical requirements
- Frequency of audits should be commensurate with risk level and degree of dependency of controls

1st Party Audit

- Carried out by an organization on itself
- Goal is iterative self improvement

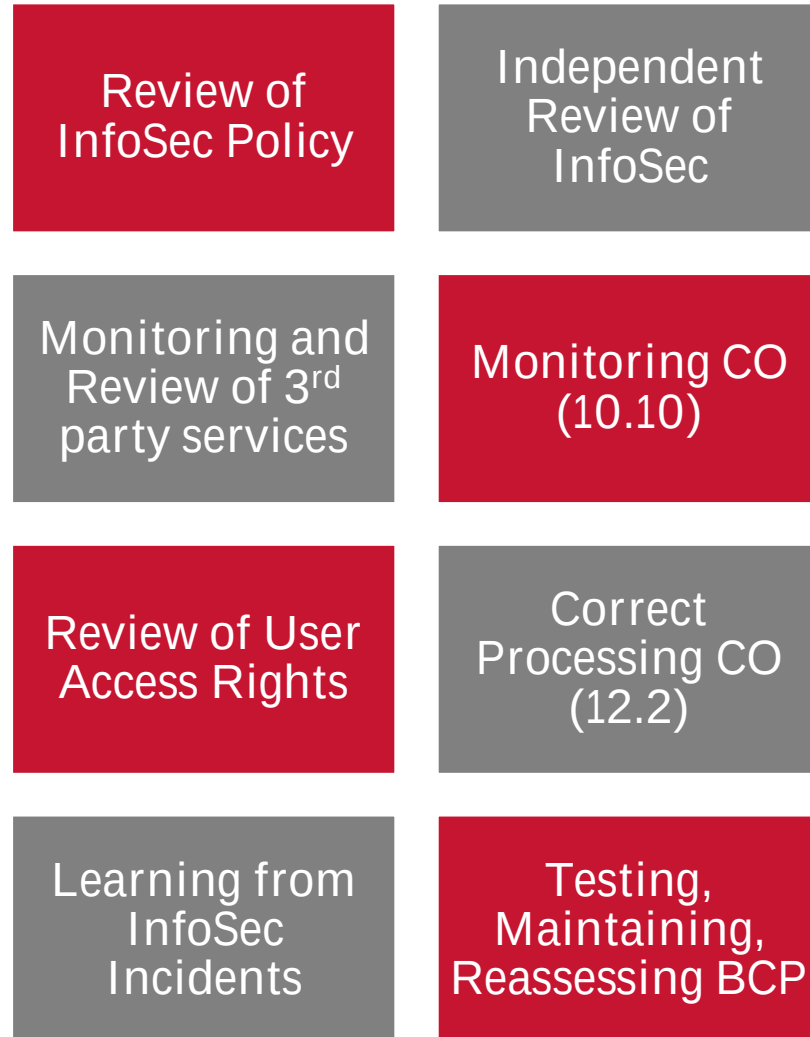
2nd Party Audit

- Carried out by a customer on a supplier
- Goal is to identify level of compliance for purposes of doing business with the organization

3rd party Audit

- Carried out by a certification body on an organization
- Goal is mainly to reduce or eliminate the need for 2nd party audits

Perform evaluation - Monitor and Review the ISMS



Reviews

- Measure effectiveness of ISMS in a changing environment
- Reviews are compiled from the following documents:
 - Internal and external audits
 - Performance reports
 - Exception reports
 - Risk assessment reports
- Corrective or improvement actions resulting from review must be executed and logged in ISMS records
- Annex A controls (Left) require these activities

Improvement

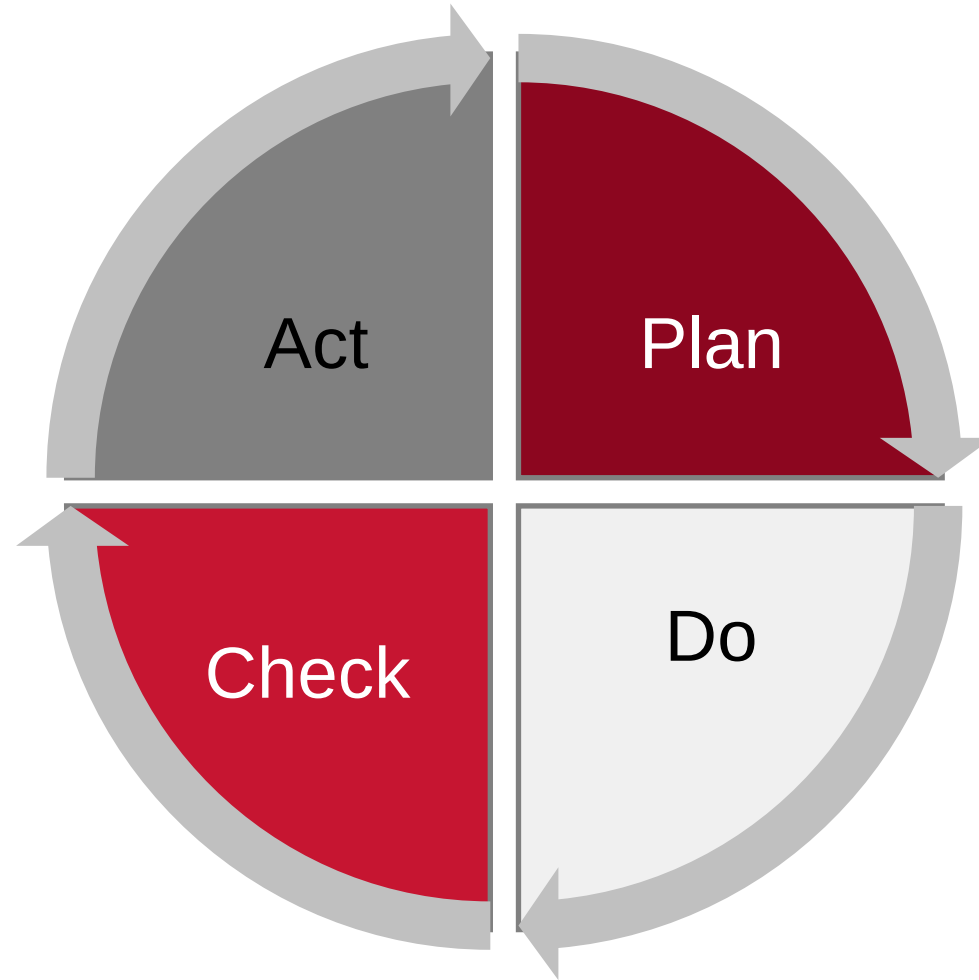
10.1 Non-conformity and corrective action

- Similar to corrective action
- Section on preventive action have been deleted

10.2 Continual improvement

- ISO 27001 gives us a system that:
- Distills the complex process of information security management into finite, manageable pieces
- Ensures the proper level of management is involved, so the program is successful
- Utilizes an internationally recognized standard (ISO 27002) for mitigation of identified risks
- Allows for effective comparisons of security management practices across organizations

The Cycle continues...



ISO 27002 - Introduction

ISO 27002 (Annex A for ISO 27001)

“Establishes guidelines and general principles for initiating, implementing, maintaining, and improving security management in an organization.”

14

Control Clauses

114

Controls

Control Clauses* of ISO 27002 (also referred as Domains)

5. Information Security Policies

6. Organization of Information Security

7. Human Resource Security

8. Asset Management

9. Access Control

10. Cryptography

11. Physical and Environmental Security

12. Operations Security

13. Communications Security

14. Systems Acquisition, Development and Maintenance

15. Supplier Relationships

16. Information Security Incident Management

17. Information Security Aspects of Business Continuity Management

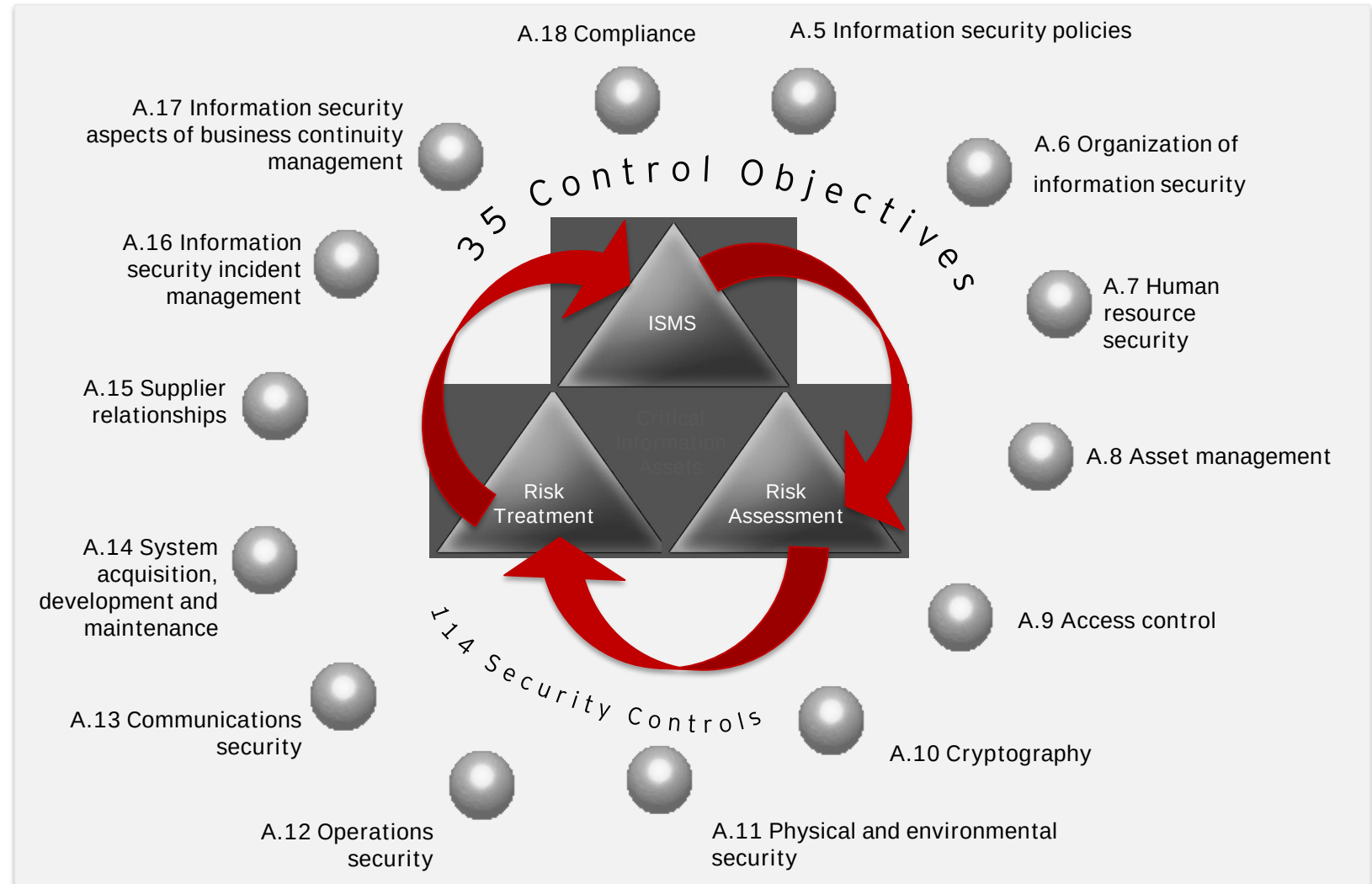
18. Compliance

Defining Statement of Applicability (SoA)

ISO 27001:2013 Clauses



ISO 27001:2013 Domains



ISMS documentation

Policies	Security policy statement	Asset management	Access control	Information security incident management	Information Security organization	Compliance
	Security objective	Business continuity	Human resource security	Physical & environmental security	System acquisition, dev & maintenance	Communication & operations management
	Supplier relationships	Information classification	Protection against malware	Logging & monitoring	Communication security	Operations security
Procedures	Asset classification procedure	Media handling procedure	Vendor management procedure	Access control procedure	Incident management procedure	Capacity management procedure
	Risk assessment procedure	Training procedure	Change management procedure	Monitoring procedure	NCCA* procedure	Backup & recovery procedure
	Legal & regulatory procedure	Governance procedure	Control of documents & records procedure	Anti-virus management procedure	Network security procedure	Patch management procedure
Templates	Information asset register template	Risk treatment plan template	Change management form	Incident reporting form	Performance evaluation template	Visitor and media movement register
	Risk assessment template	Internal audit checklist	New user access forms	Backup schedule	NCCA*	Non-disclosure agreement (NDA) template

Physical security

Information security practices

- 1 Physical security
- 2 Clear desk and clear screen
- 3 Password management
- 4 Protecting information and working off-site
- 5 E-Mail security
- 6 Internet usage and malware protection



Clear desk and clear screen



- Confirm that your screen is locked, whenever you leave your workstation by using 'Ctrl' + 'Alt' + 'Del' or Windows + L
- Clear your desks before leaving. Keep confidential information in secure storage. Keep filing cabinets shut and locked, when unattended.
- Information should never be left lying around or unattended on printers or fax machines. Empty in-trays and clear your work area before leaving it.
- In case documents containing sensitive information are no longer required, they should be shredded before disposal.

Password management

- Change your passwords at least once, every 90 days.
- Never share or divulge your passwords, even when receiving technical assistance.
- Do not use any “password saving” features in any application or software, which would defeat the purpose of requiring a password.
- Never write down or store passwords in readable format.
- Choose a password that satisfies the password policy:
 - Minimum eight characters
 - Contains upper case, lower case, digits, punctuation, non-alphabetic (not a recognizable word)
 - Different from your previous passwords



Protecting information and working off-site

- Removable media: Do not use personal media (e.g. USBs, external hard-drives, CDs/DVDs, etc.) for business.
- Data classifications: Know the data classification levels (refer to the CustomerDataClassification policy) and the required protections by level.



- Working off-site:
 - Take special care to protect cell phones and laptops from theft when working off-site.
 - Do not leave laptops visible without supervision specially in public places or in cars.
 - Use approved remote access mechanisms to access [Company]'s network when off-site.
 - Be aware of your surroundings when working off-site to reduce the risk of eavesdropping and shoulder surfing.

E-mail security

- Corporate e-mail is meant for business purposes. Do not use personal e-mails for official communications.
- Do not auto forward emails to external email addresses.
- Do not send IP, IDs and passwords or other sensitive data in an unencrypted email messages.
- Report all SPAM or phishing messages (messages from an unauthorized sender requesting personal or corporate information) as an incident.
- Emails from unauthorized senders containing attachments and links should be permanently deleted and reported as an incident.
- Employees using e-mail resources are subject to having their activities monitored by system or security personnel without any specific notice.
- Do not open emails from unknown senders.



Internet usage and malware protection

- The Internet should be used only for business needs only while at [Company].
- Content prohibited by the company should not be viewed.
- [Company] monitors and logs websites visited, files downloaded and related information exchanges over the internet and escalates to Information Security in case of breach.
- Confirm all confidential information is transferred securely through https:// (a secured protocol).
- Every user's computer should have anti-malware software installed.
- All suspected malware infections must be reported to Information Security immediately.
- Instant messaging tools should not be used without authorization.
- Do not use external software without permission.
- Symptoms of an infected system may include:
 - Slower operation or undue decrease in memory space
 - Disk drive LED lighting up for no apparent reason



Your information security responsibilities

Required employee support

Be aware

Employees must be aware of the

- ▶ ISMS policy
- ▶ ISMS objectives
- ▶ ISMS roles
- ▶ Emergency plans

Participate

Employees must participate in

- ▶ Evacuation drills
- ▶ ISMS training and awareness

Report

- ▶ Report any suspicious activity, incident or event could be a threat to [Company]'s information security (e.g. unauthorized access or changes) to Information Security
- ▶ Report any security weaknesses or vulnerabilities which you may observe (even if a breach has not occurred)

Follow

- ▶ Follow the instructions provided by management
- ▶ Follow the specific guidelines and policies defined by [Company]

Takeaways: Do's



Dos

- ▶ Lock your computer and documents every time you leave your desk
- ▶ Always carry your access badge and use it to enter the office premises
- ▶ Choose a password that is easy for you to remember but difficult for someone else to guess
- ▶ Be vigilant and report incidents
- ▶ Read information security related emails and guidelines
- ▶ Know whom to call in an emergency
- ▶ Be aware of employee safety measures
- ▶ During a crisis, give priority to personnel safety and evacuate the building

Takeaways: Don'ts

Don'ts

- ▶ Publish any sensitive (confidential or private) information on the Internet
- ▶ Talk to media during a crisis. If asked, simply say "No comment"
- ▶ Be negligent in your role in implementing an effective ISMS at [Company]
- ▶ Leave your laptop or cell phone unattended in your car or elsewhere
- ▶ Spread rumours or trust any information from unreliable sources



Gracias